

BLUF

The cybersecurity risks our organization faces are influenced by both technological vulnerabilities and human behavior. Outdated systems, exposure to a remote workforce, and high staff turnover rates highly increase the organization's susceptibility to malware, ransomware, insider threats, and social engineering attacks. Research shows that methods such as zero-trust principles, network segmentation, data encryption, structured incident response plans, and continuous behavioral training help to considerably lower the likelihood and severity of breaches (Ait Maalem Lahcen et al., 2020; Marttila et al., 2021; Saxena et al., 2020). By addressing prevention, detection, containment, legal issues, and employee training, this memo will present a thorough, evidence-based cybersecurity strategy to best safeguard company assets and guarantee operational resilience.

Encryption and Data Protection Strategy

Importance of Encryption in the Corporate Area

As documented in the FBI's annual Internet Crime Complaint Center (IC3) report, over \$20.8 billion in losses due to cybercrime were reported nationally in 2025, \$1.3 billion of which were due to personal data breaches (Federal Bureau of Investigation [FBI], 2025). These figures highlight the financial consequences associated with inadequate data protection. The growing number of financial losses demonstrate how organizations need to adopt stronger data protection methods to reduce the impact of cyber incidents. One of the best data protection methods organizations can apply is encryption.

Encryption remains one of the most effective ways to reduce the severity of data breaches. When encryption is properly implemented, it helps to protect confidentiality and limits the operational and reputational damage associated with cyber incidents. Research into

behavioral cybersecurity emphasizes that technical controls are important to help offset the inevitability of human error (Ait Maalem Lahcen et al., 2020). Encryption of data that is both at rest and in transit remains a foundational safeguard. To mitigate our company's risk of cyber incidents, we should incorporate the following encryption strategies:

- AES-256 encryption for stored corporate data
- TLS 1.3 encryption for data in transit
- Centralized cryptographic key management
- Role-based access controls
- Mandatory multi-factor authentication (MFA)

Together, these encryption strategies help create a layered, human-centric security approach that strengthens the company's data protection while supporting consistent and secure employee behavior (Grobler et al., 2021).

Assessing the Current System for Vulnerable Spots

Vulnerability assessments should combine technical scanning and behavioral risk. Research applying lifestyle-routine activity theory to cybercrime shows that there is a correlation between increased digital exposure and increased victimization (Akdemir & Lawless, 2020; Marttila et al., 2021). Businesses that have a large number of remote workers and high social media use are more vulnerable to attacks. To address these heightened risks, the organization should implement a proactive security assessment plan that includes the following measures:

- Quarterly vulnerability scanning
- Continuous patch management
- Annual third-party penetration testing
- Endpoint Detection and Response (EDR) deployment

- Asset classification and prioritization

Following this assessment plan will allow the organization to find and correct outdated and unpatched systems, which are primary exploitation pathways for threat actors (Ait Maalem Lahcen et al., 2020).

Evaluating Malware-Infected Devices

Saxena et al. recommends that if a malware infection is suspected, immediate isolation is required, as delayed containment can significantly increase the risk of lateral movement (2020).

In the case of suspected malware infection, the following steps should be take:

1. Disconnect the infected endpoint
2. Preserve all system logs and volatile memory
3. Conduct forensic imaging of the endpoint
4. Identify if any lateral movement has occurred
5. Determine the scope of the compromise

Data from the IC3 report identified more than 4,500 ransomware and malware complaints in 2025, with more than 63 new ransomware variants emerging (FBI, 2025). This data illustrates the speed at which threats evolve and the importance of having a plan in place.

Secure Software Development and Testing

The Secure Software Development Lifecycle (SDLC) processes should be embedded across multiple development environments. Grobler et al. (2021) emphasizes the importance of how usability, governance, and human interaction can impact the effectiveness of technical safeguards. It is for this reason that our organization's SDLC will incorporate:

- Static and dynamic code analysis
- Dependency scanning

- Secure configuration baselines
- Peer-reviewed code approval
- Formalized change management

This SDLC will help reduce any exploit opportunities created during development.

Table 1

Impact of Security Controls on Organizational Risk Reduction

Security Control	Risk Mitigated	Supporting Research
Encryption at rest	Reduces breach severity	Ait Maalem Lahcen et al. (2020)
Multi-factor authentication	Reduces credential abuse	Herrero et al. (2021)
Patch management	Reduces exploit success	Akdemir and Lawless (2020)
Endpoint monitoring	Limits lateral movement	Saxena et al. (2020)
Zero-trust segmentation	Reduces insider misuse	Grobler et al. (2021)

Note. Adapted from Ait Maalem Lahcen et al. (2020); Herrero et al. (2021); Akdemir and Lawless (2020); Saxena et al. (2020); Grobler et al. (2021).

Incident Response Plan

Isolation and Containment

When a cyberattack occurs, immediate isolation and containment is critical as it helps prevent a lateral spread of the attack. Our organization's incident response steps for isolation and containment include:

- Disabling any compromised accounts
- Blocking IP addresses associated with malicious activity
- Disconnecting all infected endpoints
- Activating the organization's incident command structure

Damage Evaluation

After the attack is contained, a damage assessment should be done to determine:

- Scope of the data exposure
- Impact on operational procedures
- Financial losses incurred
- Regulatory reporting consistent with all laws and obligations

Legal Considerations and Constitutional Awareness

Proper logging and chain-of-custody procedures should be maintained and practiced by the organization to best preserve digital evidence as this enables prosecution under federal statutes, such as the Computer Fraud Abuse Act (CFAA). Other Constitutional considerations to keep in mind are:

- Fourth Amendment implications when it comes to digital searches
- Privacy expectations held by employees
- Due process concerns in monitoring

Having clear acceptable use policies in place will help minimize any legal uncertainty.

Financial Fraud Kill Chain Integration

According to the FBI's 2025 IC3 report, the IC3 Recovery Asset Team was able to successfully freeze over \$679 million in fraudulent transfers using the Financial Fraud Kill Chain process (FBI, 2025). Reporting any fraudulent transfers to the IC3 Recovery Asset Team as quickly as possible significantly improves recovery outcomes. Our organization will integrate a plan to report any fraudulent transfers to this team. Our plan entails:

- Notifying the organization's financial institution immediately
- Filing a complaint with the IC3 as soon as possible

- Coordinating with federal authorities throughout the process

Mitigation Before Spread

Network Segmentation and Zero-Trust

Incorporating zero-trust and network segmentation principles limits a breach's impact by reducing lateral movement and preventing ransomware propagation (Grobler et al., 2021) . Our organization's mitigation controls are:

- Micro-segmentation
- Least-privilege access
- Continuous authentication
- Immutable offline backups

The FBI recommends keeping encrypted, immutable, and regularly tested backups to help limit any damage done by ransomware (FBI, 2025).

Behavioral Risk Mitigation

Research has shown that problematic social media use (classified as a habitual pattern of excessive social media use) increases the likelihood of cybercrime victimization (Marttila et al., 2021). Additionally, security fatigue from employees contributes to noncompliance, increasing chances of a cyberattack (Nobles, 2022). To help mitigate our organization's risk, employee behaviors should be monitored to limit potential exposure. The organization should also provide short, consistent reinforcement training and scenario-based phishing simulations to employees.

Table 2

Selected 2025 IC3 Cybercrime Loss Data

Crime Type	2025 Losses
Investment fraud	\$8.6 Billion
Business Email Compromise (BEC)	\$3.0 Billion
Tech Support Fraud	\$2.1 Billion
Personal Data Breach	\$1.3 Billion
Ransomware	\$32 million +

Note. Adapted from FBI (2025), Internet Crime Complaint Center Annual Report.

Employee Training and System Management

Training Strategy for Non-Technical Employees

Creating sustainable behavior change reduces long-term vulnerabilities faced by the organization. For example, overuse of smartphones and digital dependency directly correlate with increased cyber victimization (Herrero et al., 2021). Providing training to employees to help change their behavior can reduce their likelihood of being targeted. The employee trainings should consist of:

- Micro-learning modules that are conducted monthly
- Scenario-based phishing simulations done at least once per quarter
- Role-based cybersecurity instruction
- Corrective feedback given to employees immediately

Providing continuous evaluations to employees helps to create lasting behavior changes and improve their compliance (McNett & McNett, 2025).

Addressing Security Fatigue

According to Nobles, security fatigue reduces employees' engagement, which in turn reduces their compliance (2022). Therefore, training should be concise, relevant, and interactive to increase engagement from employees.

Building Security Culture and Leadership

Research into cybersecurity leadership emphasizes the importance of having a strong organizational culture (Triplett, 2022) . Employees who feel supported and engaged are more likely to report suspicious behavior. Especially when leadership reinforces the importance of accountability and transparency.

Conclusion

Our organization's cybersecurity risks are influenced by both technical vulnerabilities and human behavior. Encryption, structured vulnerability assessments, incident response preparedness, zero-trust architecture, and ongoing employee training greatly decrease risk exposure. By combining behavioral mitigation strategies with technical safeguards, our organization can strengthen both prevention and response capabilities.

This comprehensive plan aligns with evidence-based cybersecurity research and equips the organization to withstand evolving cyber threats.

References

- Ait Maalem Lahcen, R. A., Caulkins, B., Mohapatra, R., & Kumar, M. (2020). Review and insight on the behavioral aspects of cybersecurity. *Cybersecurity*, 3(1).
<https://doi.org/10.1186/s42400-020-00050-w>
- Akdemir, N., & Lawless, C. J. (2020). Exploring the human factor in cyber-enabled and cyber-dependent crime victimisation: a lifestyle routine activities approach. *Internet Research*, 30(6), 1665–1687. <https://doi.org/10.1108/intr-10-2019-0400>
- Federal Bureau of Investigation. (2025). IC3 Annual Report. In *Federal Bureau of Investigation*.
https://www.ic3.gov/AnnualReport/Reports/2025_IC3Report.pdf
- Grobler, M., Gaire, R., & Nepal, S. (2021). User, usage and usability: Redefining human centric cyber security. *Frontiers in Big Data*, 4, 583723.
<https://doi.org/10.3389/fdata.2021.583723>
- Herrero, J., Torres, A., Vivas, P., Hidalgo, A., Rodríguez, F. J., & Urueña, A. (2021). Smartphone Addiction and Cybercrime Victimization in the context of Lifestyles Routine Activities and Self-Control Theories: The User's Dual Vulnerability Model of Cybercrime Victimization. *International Journal of Environmental Research and Public Health*, 18(7), 3763. <https://doi.org/10.3390/ijerph18073763>
- Marttila, E., Koivula, A., & Räsänen, P. (2021). Cybercrime Victimization and Problematic Social Media Use: Findings from a Nationally Representative Panel Study. *American Journal of Criminal Justice*, 46(6), 862–881.
<https://doi.org/10.1007/s12103-021-09665-2>

McNett, J., & McNett, J. (2025). Implementing a cybersecurity continuous user evaluation program. *Journal of Cyber Security*, 7(1), 279–306.

<https://doi.org/10.32604/jcs.2025.067514>

Nobles, C. (2022). Stress, burnout, and security fatigue in Cybersecurity: a Human Factors Problem. *ideas.repec.org*. <https://ideas.repec.org/a/vrs/hjobpa/v13y2022i1p49-72n3.html>

Saxena, N., Hayes, E., Bertino, E., Ojo, P., Choo, K. R., & Burnap, P. (2020, September 7).

Impact and key challenges of insider threats on organizations and critical businesses.

<https://rrpress.utsa.edu/items/ccbc9567-3ecc-4c15-ac74-c47d6a160be7>

Triplett, W. J. (2022). Addressing human factors in cybersecurity leadership. *Journal of Cybersecurity and Privacy*, 2(3), 573–586. <https://doi.org/10.3390/jcp2030029>